- Tool Selection and the Relationship with Responsibility and Justification
  - Discussions regarding the level of pre-shipment checks and responding to external enquiries
    - Explaining to approvers: ‘We consider this sufficient as we are using this widely adopted tool’
    - Commercial tools are preferred over OSS tools due to the trust that approvers place in them
      - OSS tools are not subject to approval processes, so they remain unknown
    - It will likely be the role of the OSPO to ensure that approvers understand the situation without misunderstanding
    - When it comes to fulfilling accountability, commercial tools are easier to use as they come with pre-prepared materials. With OSS tools, (as we are using them at our own risk)
  - Ultimately, the decision will be based on balancing the expected frequency of issues against the cost of countermeasures, so it will need to be determined taking into account each company’s business model and scale
    - It might be useful if this OSPO Sub-WG could propose a tool selection algorithm and evaluation formula
    - The maturity of the OSS will also be a factor in determining which tool is best

- Generative AI and OSPO
  - OSS governance and the governance of generative AI usage are similar: similarities in best practices
  - https://atmarkit.itmedia.co.jp/ait/articles/2601/14/news052.html

- Checkpoints for selecting SCA tools
  - Software Composition Analysis tool
- Distinguishing by SCA Tool Output
  - Tools that identify and list the software components contained
    - Tools that identify components and list their names, licences, copyright details, etc.
    - The method used to identify components varies depending on the tool and its options
  - A type that identifies and lists patterns in the licence text, copyright information, and legal keywords related to licences within the software being scanned (e.g. FOSSology)
    - Identifies and lists the directory containing the information indicating the licence
      - If the directory structure and naming conventions are appropriate, pairs of component names and licences can be created
- Distinctions in scanning methods
  - Cross-referencing the OSS database with the target software
  - Identify patterns in the licence text, copyright information, and legal keywords related to the licence of the software being scanned
  - Use AI to compare the target software with the OSS code database, utilising AI-based code analysis to ensure high accuracy (see https://semcl.one/)
    - The accuracy of snippet detection appears to be high
  - Binary scan
    - Determination based on matching symbol names in the symbol table against those in the database
    - Examines the similarity of binary code patterns (fingerprints)
- Candidate checkpoints
  - If the repository's directory structure is appropriate, keyword search types can also be useful
    - If developers using OSS are well-trained and follow best practices, this type may suffice
  - If the discovery of code snippets is a priority, select a tool with a component detection algorithm suited to this
  - There will likely be specific checkpoints depending on each company's ultimate purpose, workflows, and where in the process the tool is used

The OpenChain Project Japan Working Group / CC0-1.0

- Accuracy
  - Accuracy improves when source code is managed properly
  - Situations where binary scanning is required
    - When receiving a binary release
    - Wanting to know how it appears to the recipient
    - To check whether unintended source code has been compiled
    - Are any unintended external libraries being linked?
  - It is impossible to achieve 100% accurate scan results with SCA tools
    - It is better to consider improving accuracy by combining various methods, such as coding practices and code formatting tools, rather than relying solely on SCA tools
- Binary scanning methods
  - Identify issues by analysing characteristics and patterns, such as symbol names

 The OpenChain Project Japan Working Group / CC0-1.0

- What to do when a violation is reported by an external party
  - Expected complaint:
    - “Are you using the GPL software called XXX? Please provide the source code.”
    - Who should contact us?
      - ① OSPO-type organisations, ② the company’s enquiry desk, ③ the product’s support desk, ④ via public repositories, ⑤ Information was shared on external social media, ⑥ An employee was personally approached by an external party
  - Action:
    - It is necessary to ensure that anyone who receives an enquiry or information promptly contacts the appropriate internal department (OSPO)
    - Investigate whether XXX is actually being used
      - Identify and confirm with the project members who developed (or handled) the relevant product
      - Investigate product records (stored source repositories)
      - If third-party software is integrated, contact the relevant supplier
    - Scan the product binaries to verify
    - If it is determined that XXX is not included:
    - If it is confirmed that XXX is included:
      - First, consider whether the source code can be provided
      - If it is determined that the source code cannot be provided
        - Technical response
          - » Discontinue product sales
          - » Modify the product to exclude XXX and resume sales
        - Business-side response
          - » Acknowledged the infringement and discussed the response with the rights holder
  - It is important to take care from the early stages of development to ensure that such issues do not arise in the first place
    - Exercise caution throughout the entire supply chain, including external procurement
    - This is also an important part of the OSPO’s role

What would happen if there were no OSPO?

The OpenChain Project Japan Working Group / CC0-1.0